

PROGRAMA TÉCNICO EN CIBERSEGURIDAD

EXAMEN FINAL:

Análisis e Investigación Forense Digital

Estudiante: Ruth Elizabeth Lindo Lindo

Profesor: Diego González Villachica

Fecha de entrega: 04/19/2026

I Parte

Repaso de Conceptos:

1. Defina y provea algún ejemplo de “Misuse or abuse of authorized access; automated intrusion”.

Se refiere al uso indebido de credenciales legítimas para realizar acciones no autorizadas y se produce cuando un usuario con credenciales válidas (empleado, administrador, contratista) utiliza su acceso autorizado para fines indebidos, o cuando un atacante roba esas credenciales y las usa de forma automatizada para infiltrarse en sistemas.

Por ejemplo: Un empleado con accesos podría robar datos o manipular cuentas o información de acuerdo con sus intenciones como en 2020, un empleado de Twitter con acceso interno fue manipulado por atacantes para modificar cuentas verificadas y publicar mensajes fraudulentos (el famoso “Bitcoin scam”). Aquí se combinó abuso de privilegios y automatización para ejecutar acciones masivas dentro del sistema.

2. Defina y provea algún ejemplo sobre “C2 traffic”:

Es la infraestructura que permite a un atacante mantener comunicación remota con sistemas comprometidos. El tráfico C2 es el flujo de datos entre el malware instalado en la víctima y el servidor del atacante. Se utiliza para enviar órdenes, recibir resultados, exfiltrar datos o descargar nuevas cargas maliciosas.

Por ejemplo: Uno de los incidentes más conocidos internacionalmente es el de ransomware, ya que, el C2 coordina la propagación del malware y la gestión de claves de cifrado, como en el caso ransomware WannaCry en el 2017, que utilizó un servidor C2 para coordinar la propagación del malware y gestionar las claves de cifrado.

3. Según, la metodología funcional de investigación forense digital vista en la clase #6, explique en qué consisten las siguientes etapas:

a. Preliminary Correlation:

La idea principal es de unir información que tienen factores en común de tal forma, que, la investigación sea orientada por medio de conjunto de eventos conectados. El objetivo es descubrir si esos eventos están relacionados y podrían formar parte de un mismo incidente.

Se siguen algunos pasos como:

- Se revisan los registros (logs) de distintos sistemas: red, firewall, antivirus, servidores, etc.
- Se busca si varios eventos ocurren cerca en el tiempo o comparten IP, usuario o patrón, algo que los pueda enlazar de alguna forma.

Por ejemplo: Un intento de acceso fallido seguido de una conexión sospechosa desde la misma IP podría ser un posible ataque de fuerza bruta.

b. Event Normalization:

Este paso implica buscar uniformidad de datos con el fin de obtener una base de datos limpia y uniforme para aplicar reglas de análisis. Al usar diferentes tipos de dispositivos como servidores, firewalls, routers, entre otros; se necesita de alguna manera unificar los hallazgos y eso permite una mejor documentación e interpretación de los datos encontrados.

c. Kill Chain Analysis

El objetivo de este paso es colocar los eventos normalizados en cada fase para entender cómo avanzó el atacante desde la perspectiva del mismo atacante. Lo cual, permite identificar dónde se pudo haber detenido el ataque y qué controles fallaron o cuales son los escenarios mas probables de modo que, brinda una cronología completa del ataque con evidencias y puntos de mitigación aplicables y así minimizar el riesgo de ataque. Las fases del Cyber Kill Chain son:

1. Reconocimiento (Reconnaissance):

Objetivo: Investigar y reunir información antes de formular conclusiones o tomar algún tipo de medida:

- Observa la empresa, sus empleados, correos, redes sociales y sistemas.
- Busca información útil: direcciones IP, nombres de dominio, correos, versiones de software.

Analogía: como un secuestrador que estudia una casa antes de entrar, “mapea” el sistema para encontrar puntos débiles.

2. Preparación del arma (Weaponization):

Objetivo: el atacante crea su herramienta de ataque:

- Combina un exploit (forma de aprovechar una falla) con un payload (código malicioso).
- Prepara el archivo o enlace que usará para infectar. Esto podría ser una bomba lógica, un ransomware, entre otros.

Analogía: Como cuando un secuestrador prepara una llave maestra para abrir las cerraduras estudiadas anteriormente de una casa.

3. Entrega (Delivery):

Objetivo: Aquí el atacante envía la herramienta de ataque:

- Envío de correo electrónico, archivos de descargas, USB, o sitios web falsos para redirigir a la víctima a un enlace que descarga el archivo de infección.

Analogía: Como cuando un secuestrador usa la llave maestra e intenta abrir la cerradura de la casa para probar la efectividad de la llave.

4. Explotación (Exploitation):

Objetivo: El ataque se activa:

- El usuario abre el archivo o hace clic en el enlace.
- El exploit aprovecha una vulnerabilidad del sistema.

Analogía: Como cuando un secuestrador logra abrir la cerradura de la puerta y entra a la casa.

5. Instalación (Installation):

Objetivo: el atacante se asegura de quedarse hasta lograr el objetivo final:

- Instala software malicioso (como un troyano, backdoor o aplica un ransomware).
- Crea persistencia para re-infectar si el sistema se reinicia.

Analogía: Como cuando un secuestrador una vez dentro, pone cámaras que monitoreen la actividad de la víctima.

6. Comando y Control (C2):

Objetivo: el atacante toma el control remoto del sistema:

- El malware se conecta a un servidor externo para recibir órdenes.
- Se usa tráfico cifrado para ocultar la comunicación de tal forma que la víctima puede no darse cuenta de que su sistema está infectado por cierto tiempo mientras, se causa daño irreversible.

Analogía: Como cuando un secuestrador manipula las cámaras a su antojo con el objetivo de obtener diferentes ángulos de la casa mientras logra su objetivo.

7. Acciones sobre el objetivo (Actions on Objectives):

Objetivo: el atacante finalmente cumple su propósito:

- Roba información, cifra archivos, borra datos o espía actividades.

Analogía: Como cuando un secuestrador usando la información de su rutina, secuestra a la víctima con éxito.

II Parte: Comprensión de Conocimiento

4. Explique brevemente dos delitos informáticos estipulados en la Ley de Delitos Informáticos de Costa Rica. Indique el número de artículo donde encontrarlo, ejemplo: Artículo 231 o 232, etc.

1. Espionaje informático:

Artículo 231- Este delito ocurre cuando una persona accede sin autorización a sistemas informáticos para obtener, copiar o destruir información que tiene valor económico o comercial.

Pena: de tres a seis años de prisión.

2. Propagación de malware:

Artículo 232- Se castiga a quien instale o difunda programas maliciosos (virus, troyanos, ransomware, etc.) que afecten el funcionamiento de sistemas o dañen datos.

Pena: de tres a ocho años de prisión.

5. Según la guía sobre abordaje de investigaciones forenses, propuesta en la clase #13, explique brevemente tres razones destacando la importancia y/o beneficios sobre “La discusión o etapa inicial”.

1. Definir qué pasó y qué investigar:

Es importante definir los alcances de la investigación, de no ser así, podría convertirse en un caso de no acabar.

Beneficio: evita investigar cosas irrelevantes y asegura que el análisis tenga un rumbo claro y objetivos definidos.

2. Asegurar recursos y límites del caso:

Aquí se decide si la investigación será interna, civil o penal, cuánto tiempo y presupuesto hay, y qué apoyo se necesita, ya que el análisis incluye muchas horas de estudio y diversas herramientas, entre otras metodologías que al final tienen un costo total real.

Beneficio: garantiza que el trabajo sea realista y que no falten herramientas ni permisos.

3. Coordinar con las personas involucradas:

Se obtiene aprobación para entrevistar personal, acceder a documentos y trabajar con equipos de respuesta a incidentes.

Beneficio: mejora la colaboración y evita problemas legales o de autoridad durante la investigación.

III Parte: Desarrollo de caso & Exposición Virtual

6. Tome en cuenta la guía sobre abordaje de investigaciones forenses, propuesta en la clase #13, y con ella, utilice preguntas para analizar cómo investigaría alguno de los casos propuestos a continuación. Sólo escoja un caso para desarrollar.

Elabore un texto de su análisis y luego expóngalo en el video. **Los que expongan en idioma inglés recibirán un incentivo la próxima clase 22-Abril-2026.**

Investigation

CASE STUDY #2: NETWORK DATA REVEALS THEFT OF TRADE SECRETS

After I read the case, I started developing the investigation guidance I saw in class, and for each point, I formulated a question:

1. Initial Discussion

Question: What happened and why is it important?

Answer: An Apple engineer, Xiaolang Zhang told his manager that he would be working for an electric car company in China. However, right before his resignation, his network activity was unusual. Knowing this information is critical as it defines the direction of the investigation and prevents wasting time on irrelevant data. In these cases, the investigation must be done before the resignation is completed as the worker may disappear.

2. Event Details

Question: When and how was the incident detected?

Answer: When the company security noticed unusual activity in the days before Zhang's resignation. His downloads and searches were far above normal. This triggered an internal investigation.

3. Technical Details

Question: What digital evidence exists?

Answer:

Records from Apple's network that proved Zhang was searching and downloading far more files than normal, all at once.

Investigators looked at his company-issued phones and laptop to see if files had been copied or transferred.

Logs from Apple's databases that proved he accessed and downloaded secret company information.

The unusual downloads happened right after he said he was quitting, showing a clear link between his resignation and recent illegal actions.

4. Scene Details

Question: Where did the suspicious activity occur?

Answer: Inside Apple's internal network, using company-issued devices. In digital forensics, the "crime scene" is not a physical place, but the technology involved. Here, it includes Apple's servers (where the secret files were stored) and Zhang's devices (where the files were accessed or copied).

5. Identify Witnesses

Question: Who can provide testimony or context?

Answer:

Zhang's manager, who received the resignation and grew suspicious.

The security team that reviewed logs and devices confirming the facts.

Colleagues who may confirm changes in Zhang's behavior or unusual requests.

6. Identify Suspects

Question: Who is the main suspect?

Answer: Xiaolang Zhang himself, since he had legitimate access and admitted to taking company data. No other suspects were identified. Therefore, there is no confirmation or suspicion that he was working with somebody else to commit the fraud.

7. Modus Operandi (Attack Method)

Question: How was the theft carried out?

Answer:

Used valid credentials to access secret databases.

Conducted bulk searches and targeted downloads of sensitive files.

Did this activity in a short period before leaving the company.

Planned to move to China and work for a competitor, who most probably offered him a position in exchange of the stolen data.

8. Technical Evidence

Question: What supports the case in court?

Answer:

Visual evidence of network traffic rising far above typical levels.

A list of the files that were downloaded, showing that the suspect accessed secret company information.

An examination of the suspect's work devices (phones and laptop) that confirmed data was copied or taken from them.

Zhang admitted he took the data which was taken as proof.

The FBI formally charged Zhang with theft of trade secrets, using the collected evidence to support the case.

IV Parte: Puntos Extra

Adjuntar un pantallazo de la carpeta de este curso que demuestre las tareas, documentos, notas, y proyectos realizados por cada uno.

